PHASE 1D · PRODUCTION HARDENING AND CLOSURE

EngiSignal Phase 1 Closure

What is genuinely production-ready, what is only partly built, and what is still nothing but an interface. Every claim below was checked against the deployed application or the database behind it — not against intent.

Deployment engi-signal.vercel.app **Commit** dc3caf5 **Verified** 15 Aug 2026
Scope File-based ingestion

ESLINT	TYPECHECK	TESTS	PROD BUILD
0 problems	0 errors	432 / 432	Pass

RLS COVERAGE
28 / 28

A What is fully production-ready

Each of these was exercised against the live deployment with real files and a real authenticated account, not in a test harness.

VERIFIED

The complete import workflow

Upload → detect → map → validate → preview → commit → persist, end to end in production. A 180-row FlexNet export and two multi-sheet workbooks were imported and their records read back after signing out and in again.

VERIFIED

Source auto-detection

FlexNet identified at 95% confidence with its evidence shown to the user — vendor-daemon terminology, `FEATURE` column, issued/in-use counters. Detection is evidence-bearing rather than a bare label.

VERIFIED

Column mapping with confirmation

Every proposal carries a confidence and a real sample value from the file, and every one is editable before commit. Nine columns mapped correctly on the production test, including the distinction between `LICENSES_ISSUED` as capacity and `LICENSES_IN_USE` as concurrency.

VERIFIED

Row-level validation

Accepted plus rejected always reconciles to rows read, and the total is shown to the user. Rejected rows are stored as an audit record and never reach analysis.

VERIFIED

Tenant isolation

Row Level Security is enabled on all 28 public tables, every one carrying policies. A second tenant could not reach the first tenant's imports; requests returned 404 and the other tenant's data was untouched.

VERIFIED

Authentication and workspace provisioning

Real email-and-password auth. Organizations are provisioned by a `SECURITY DEFINER` function that derives the owner from `auth.uid()`; the client never supplies an organization id or a role.

VERIFIED

Import idempotency

A content fingerprint over file bytes, dataset and mapping. Re-uploading the same file returns `409` with the existing import id instead of double-counting. A corrected mapping is treated as a legitimately different import.

VERIFIED

Per-import deletion

Deleting one import left the other intact and analytics recomputed against what remained. Canonical records are stored at source grain, so a single import can be withdrawn without un-aggregating anything.

VERIFIED

Deterministic analytics on imported data

P90 / P95 / P99, capacity headroom, utilization and right-sizing run on real imported records. A production import produced **P95 = 64**, matching an independently computed expectation.

VERIFIED

Honest insufficient-data states

Absent denial data renders "Denial data not supplied", never "0". A two-day import correctly withheld the percentile capabilities rather than computing a P95 from two observations.

VERIFIED

Analytics equivalence guarantee

A regression test asserts that data arriving through the ingestion pipeline produces byte-identical hourly concurrency, daily peak, percentiles and right-sizing to the same data supplied directly. There is one analytics engine, not two.

B What remains partial

MOST CONSEQUENTIAL GAP

Cost data has no import path. The capability matrix gates "Financial opportunity" on `cost`, and `hasCost` resolves from `contractItems[].unitPrice`. But `CanonicalEntitlementRecord` carries no price field, the pipeline sets `unitPrice: null` unconditionally, and the import screen offers only Usage, Entitlements and People.

Nothing here is dishonest — the UI correctly says "requires contract or cost data" and never invents a number. But a customer currently has no way to supply that data, so the financial analysis cannot be reached through the product at all. Since financial opportunity is the commercial payload, this is the first thing to build.

PARTIAL

Email delivery

No custom SMTP is configured; the project uses Supabase's built-in mailer, whose rate limit was hit during testing. Signup confirmation and password reset work mechanically but are not viable at production volume. This needs a real transactional email provider before external users.

PARTIAL

Identity resolution

Deterministic and safe by design — features merge only on an exact normalized match or a confirmed alias, and users only on username, employee code or email. Never on name similarity. Review queues exist for unmapped features and unmatched users, but resolution at the scale of a large estate has not been exercised.

PARTIAL

Ask EngiSignal

The provider abstraction and the retrieval layer exist, and the no-key path answers from deterministic analytics using templates. No AI provider key is configured, so no model is in the loop. This was deliberately left untouched this phase.

PARTIAL

Scale characteristics

The largest production import was 180 rows. Limits are configured at 500,000 rows and 25 MB, but nothing near that has been run against the deployed serverless environment, where request duration and memory are bounded.

C What remains roadmap

None of the following exists as working functionality. They are listed so nothing here is mistaken for shipped.

INTERFACE ONLY

Live license-server collectors

`lib/connectors/` contains types and a registry. Every entry reports `available: false` and no connector is implemented. There is no daemon connectivity, no polling, no synchronization. The product reads exports you already have, and the UI says exactly that.

NOT STARTED

Billing and subscriptions

No Stripe integration, no plans, no metering.

NOT STARTED

SSO and SCIM

Authentication is email and password only. No SAML, no directory provisioning

provisioning.

NOT STARTED

Team membership management

An organization is created with its first user as owner. There is no invitation flow, so a workspace is effectively single-user.

EXCLUDED

Legacy `.xls` workbooks

The bundled parser reads OOXML only. BIFF files are detected by their OLE2 signature and rejected with instructions to re-save, rather than failing obscurely.

D

Security findings

FIXED

Service-role key removed entirely

`adminClient()` was an unused RLS bypass and was deleted. This session also removed `SUPABASE_SERVICE_ROLE_KEY` from `.env.example` and the deployment guide: asking operators to provision a credential that bypasses tenant isolation, for code paths that no longer exist, is blast radius with no capability behind it. Every database call now runs as the signed-in user.

FIXED

User deletion did not cascade

Deleting an account previously orphaned its memberships, organizations, imports and usage rows. A foreign key with `ON DELETE CASCADE` now removes memberships with the user, and an `orphaned_organizations` view surfaces workspaces left without members. Both were confirmed working during this phase's teardown.

FIXED

Rate limits misreported as user error

A 429 from the auth service carries the word "email" in its text, and the earlier message mapping matched that first — telling people their address was invalid when the service was merely throttled. Specific causes are now checked before keyword fallbacks.

VERIFIED

No user enumeration

Sign-in failure reports "That email and password do not match an account" — confirmed live against a non-existent address. Password reset always reports success regardless of whether the address is registered.

VERIFIED

Redirect allow-listing

The auth callback's `safeNext()` rejects non-relative redirect targets, so a crafted link cannot bounce a freshly authenticated session off-site.

VERIFIED

Errors do not leak internals

Parse failures log the real exception server-side and return a generic message to the client. This is what finally diagnosed the XLSX investigation in section H.

VERIFIED

Session revocation

After the test account was deleted, its still-present cookie granted nothing. All eight protected routes redirected to sign-in and the ingestion API returned `401`.

REVIEWED

Supabase advisor warning — accepted by design

The linter flags `bootstrap_organization` as a `SECURITY DEFINER` function callable by authenticated users. Reading the body, the escalation is bounded: it refuses an unauthenticated caller, derives the owner from `auth.uid()`, fixes the role to `owner` rather than accepting one, returns an existing membership instead of creating duplicates, and pins `search_path` — which closes the classic attack on this pattern. The warning flags the shape, not a defect here.

QA residue

The temporary verification account was deleted and every table checked afterwards. Users, organizations, memberships, imports, mappings, canonical usage, entitlements, people, rejections, features, employees, hourly and daily usage, contracts and both review queues all return **zero rows**. The codebase contains no QA credentials, test emails, hard-coded organization or import ids, and no debugging bypasses; the only `example.com` references are test fixtures and a sample row in a downloadable template, using the domain reserved for exactly that purpose.

E Supported import formats

FORMAT	EXTENSIONS	STATUS	NOTES
Delimited text	`.csv` `.tsv` `.txt`	PRODUCTION	Delimiter sniffed from the header line across comma, tab, semicolon and pipe, so a description field further down cannot outvote the real delimiter.
OOXML workbook	`.xlsx`	PRODUCTION	Verified end to end in production on 15 Aug. Multi-sheet: a two-worksheet workbook was read across both sheets and committed.
Macro-enabled workbook	`.xlsm`	PRODUCTION	Verified end to end in production on 15 Aug with a distinct two-sheet workbook. Macros are not executed; only the cell data is read.
Legacy workbook	`.xls`	REJECTED	Detected by OLE2 signature and refused with instructions to re-save as .xlsx — a clear refusal rather than a confusing parse failure.

Format is decided by content, not by extension: a file named `usage.csv` that is really a workbook is parsed as a workbook, because an export named by hand is a routine thing and misreading it silently is not.

F Supported license-manager exports

All five are **file-based adapters**. Each recognizes the vocabulary of that vendor's export and maps it to the canonical model. None of them talks to a license server.

SOURCE	DETECTION	FILE IMPORT	LIVE COLLECTOR
FlexNet /	Vendor daemon, FEATURE,	VERIFIED IN PROD	NONE

FLEXlm	issued/in-use counters		
RLM	RLM-specific column vocabulary	ADAPTER + TESTS	NONE
DSLS	DSLS-specific column vocabulary	ADAPTER + TESTS	NONE
Sentinel	Sentinel-specific column vocabulary	ADAPTER + TESTS	NONE
Generic tabular	Fallback with alias matching	ADAPTER + TESTS	N/A

> READ THIS DISTINCTION CAREFULLY
>
> Only FlexNet has been exercised against the deployed application with a real file. The other four are covered by adapters and fixture tests but have not been run through production. Before a pilot involving RLM, DSLS or Sentinel, obtain one genuine export of that kind — real exports carry quirks that hand-built fixtures do not.

G Capability matrix

This lives in exactly one place — `lib/ingestion/capabilities.ts`. It was previously duplicated, which meant the import screen and the data screen could disagree about what the same data supported. The duplicate was removed this phase.

CAPABILITY	REQUIRES	REACHABLE TODAY
Usage trends	`usage`	YES
Daily demand	`usage`	YES
P90 / P95 / P99 demand	`usage + concurrency`	YES — needs ≥ 14 days of history
Capacity headroom	`usage + concurrency + entitlements`	YES

Utilization	`usage + concurrency + entitlements`	YES
Unmet demand	`usage + denials`	YES
Organization allocation	`usage + people`	YES
Financial opportunity	`usage + entitlements + cost`	NO IMPORT PATH

Seven of eight are reachable by importing files the customer already has. The eighth is blocked as described in section B.

H

Production test results

TEST	RESULT	EVIDENCE
FlexNet CSV import, 180 rows	PASS	P95 = 64, matching an independent calculation
XLSX multi-sheet import	PASS	Sheets March + April read; 3 rows accepted, 0 rejected; committed
XLSM multi-sheet import	PASS	Sheets May + June read; 3 rows accepted, 0 rejected; committed
Duplicate upload	PASS	`409` carrying the existing import id; no double-count
Per-import deletion	PASS	Imports 7 → 6, usage rows 184 → 183, other import intact
Session survives sign-out	PASS	Imported records present after re-authentication
Cross-tenant access	PASS	404 on another tenant's import; their data unaffected
Deleted-user session	PASS	8 protected routes redirect; API returns 401

Invalid sign-in	PASS	Non-disclosing message; no account enumeration
Capability gating	PASS	Matrix responded correctly to entitlements, denials and people imports
Insufficient history	PASS	Two-day import withheld percentiles rather than computing them
Layout at 1440 and 390	PASS	No horizontal page overflow at either width
Console errors	PASS	Zero on landing and sign-in pages
Post-teardown residue	PASS	Zero rows across all 16 checked tables

WORTH RECORDING — THE XLSX FALSE ALARM

XLSX and XLSM appeared to fail in production with a 422 while identical bytes parsed locally. Two hypotheses were wrong before the real answer surfaced: the `serverExternalPackages` bundling theory was already satisfied in `next.config.ts`, and the route's catch block was swallowing the cause.

Adding server-side logging revealed `Corrupted zip: missing 132 bytes` — and the server had received 7,219 bytes for a 7,351-byte file. **The base64 test harness was truncating the upload; the application was never broken.** Re-running through the actual file input passed immediately. The lesson is worth